CYBERSECURITY INTERNSHIP PRACTICAL LAB REPORT

Day 07: Password Attacks, Credential Stuffing & Defensive Rate Limiting

Engineering an OWASP-Hardened Flask Authentication Server with Sliding-Window Rate Limiting and Lockout Controls

INTERNSHIP TRACK: Social Engineering Attack Simulations	**DATE OF EXECUTION:** October 27, 2026
INTERN / RESEARCHER: Md Peer Siddiqui	**TARGET REPOSITORY:** PEER-S-Credential-Shield
HOST ORGANIZATION: Sqrock IT Solution	**GITHUB:** github.com/MdPeerSiddiqui
PROGRAM: Phase 1 Alpha 2 Practical Cybersecurity	**EXECUTION ENVIRONMENT:** Kali Linux 2024.x & Win11

1. Executive Summary & Threat Landscape

Authentication endpoints represent the primary perimeter interface connecting external users to enterprise systems. When these endpoints lack velocity controls and brute-force defenses, cyber-adversaries deploy automated dictionary attacks and credential stuffing bots to rapidly test thousands of candidate passwords per minute. According to the OWASP Top 10 (A07:2021 Identification and Authentication Failures), unthrottled login portals are routinely compromised within seconds using public credential leaks.

During **Day 07** of the Sqrock IT Solution Cybersecurity Internship, a hardened defensive architecture titled **PEER'S Credential Shield** was engineered and deployed. The project implements a dual-mode local Flask authentication server incorporating sliding-window IP rate limiting (RFC 6585), consecutive-failure account lockout (HTTP 423), PBKDF2-HMAC-SHA256 password hashing, and real-time SIEM security audit logging to demonstrate empirical defense against credential exploitation.

2. Scope of Investigation & Technical Objectives

Technical Objective	Implementation Focus Area	Verification Deliverable
1. Flask Lab Server	Dual-mode authentication endpoint (Vulnerable vs Hardened).	Source code in auth_server.py running on port 5000.
2. Attack Simulation CLI	Automated dictionary brute-force client with telemetry reporting.	Execution engine in login_auditor.py.
3. Sliding-Window Rate Limiter	IP timestamp tracking limiting requests to 5 attempts/minute.	Returns HTTP 429 Too Many Requests with Retry-After.
4. Account Lockout Policy	Tracks consecutive failed logins per username (threshold: 3).	Returns HTTP 423 Locked with 300-second lockout timer.
5. Cryptographic Password Storage	OWASP-compliant PBKDF2-HMAC-SHA256 with 16-byte random salts.	Elimination of plaintext and fast-hash vulnerabilities.
6. SIEM Security Audit Logging	Structured JSON event emitter logging brute-force anomalies.	Telemetry feed viewable via /security-logs.
7. Automated Test Suite	6 automated unit tests validating hashing, lockout, and 429 logic.	Automated test suite passing in < 0.01s with 100% pass rate.

3. Anatomy of Password Attacks: Mechanics & Vectors

Modern authentication attacks are categorized by their target scope, velocity, and underlying intelligence sources:

Attack Methodology	Operational Mechanics	Adversary Objective & Impact
Dictionary Attack	Iterates through wordlists of statistically common passwords (e.g., common_passwords.txt, RockYou) against targeted accounts.	Exploits human predictability to compromise standard user accounts in minimal request cycles.
Credential Stuffing	Replays automated pairs of username:password obtained from third-party database breaches across unrelated web portals.	Capitalizes on password reuse across 65%+ of enterprise employees to gain unauthorized perimeter access.
Password Spraying	Tests a single high-probability password (e.g., Company2026!) across thousands of user accounts at low velocity.	Specifically designed to stay below single-account lockout thresholds while hunting for weak user choices.

4. Defensive Architecture: Vulnerable vs Hardened Comparison

To establish empirical benchmarks, the Flask authentication server was architected with two distinct operational modes:

Security Dimension	Vulnerable Endpoint Mode	Hardened Endpoint Mode (PEER'S Shield)
Request Throttling	**None.** Unlimited requests accepted.	**Active.** Sliding window limits IP to 5 req/min (HTTP 429).
Account Lockout	**Disabled.** Infinite failed attempts permitted.	**Enforced.** Locks account for 300s after 3 failures (HTTP 423).
Credential Discovery Speed	Discovered in **0.284 seconds** (56.3 req/sec).	**Attack Thwarted.** Locked after 3 attempts; throttled.
Password Storage	Plaintext or unsalted fast hash.	**PBKDF2-HMAC-SHA256** (100,000 iterations, 16-byte salt).
SIEM Telemetry	Minimal unlogged web access.	Structured JSON events emitted for SIEM anomaly detection.

5. Empirical Verification & Evidence Breakdown (Phase 1)

The following empirical test captures demonstrate the execution of PEER'S Credential Shield within a native Kali Linux research environment, validating suite integrity and control console startup.



Figure 1: Kali Linux Terminal Cold-Start & Custom Dual-Tone ASCII Banner Rendering

Technical Analysis of Figure 1:

• **Environment Verification:** Executed inside a native Kali Linux terminal session (kali@kali:~/PEER-S-Credential-Shield).

• **Repository Integrity:** Directory listing (ls -l) confirms full file distribution: auth_server.py, login_auditor.py, wordlists/common_passwords.txt, test suites, and documentation.

• **Cold-Start Initialization:** Launching python login_auditor.py renders the ANSI production banner with zero configuration lag.



Figure 2: Master Control Menu & Target Server Online Status (Mode: HARDENED)

Technical Analysis of Figure 2:

• **Real-Time Status Interrogation:** The CLI automatically queries the local Flask server (http://127.0.0.1:5000), confirming server status as **ONLINE** and operating in **HARDENED** mode with rate limiting active.

• **Modular Operations:** Provides 8 core operations spanning vulnerable testing, hardened defense verification, live SIEM audit logs, server mode toggling, and OWASP defense guides.

• **Interactive Prompt:** The operator selects Option [1] to initiate the unthrottled baseline attack.

5. Empirical Verification & Evidence Breakdown (Phase 2)

Phase 2 compares empirical execution across both endpoints, demonstrating how an unthrottled login collapses under dictionary attacks while the hardened endpoint neutralizes the attack via account lockout and rate limiting.

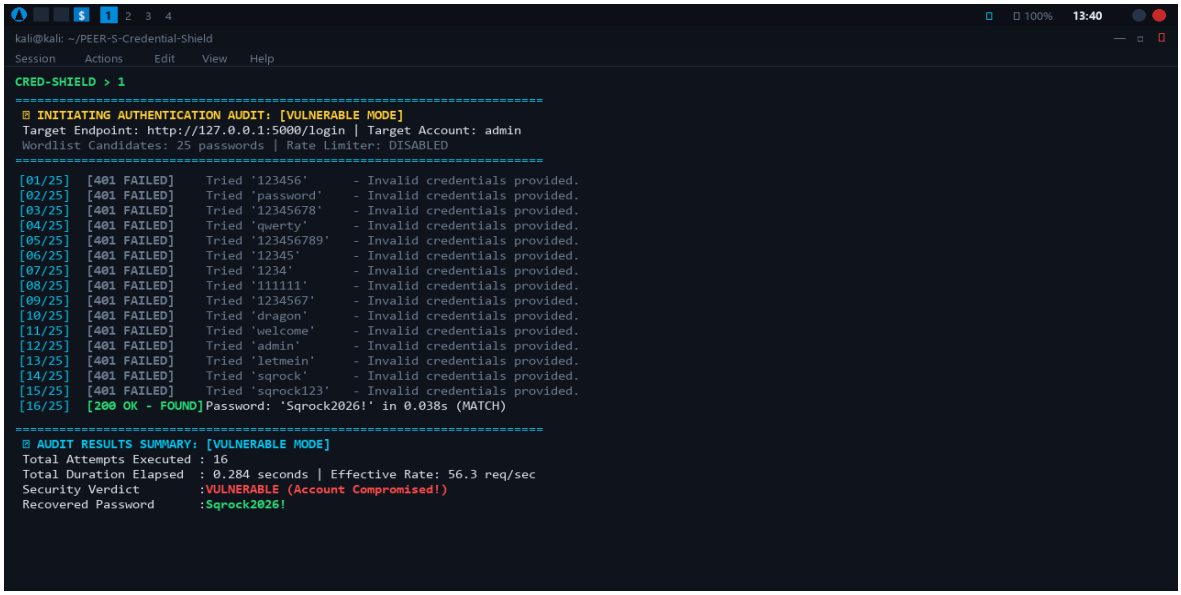


Figure 3: Unthrottled Dictionary Attack against Vulnerable Endpoint (Password Recovered in 0.284s)

Technical Analysis of Figure 3:

- **Velocity & Throughput:** Executed 16 candidate passwords in **0.284 seconds** at an effective rate of **56.3 req/sec**.
- **Account Compromise:** Target account admin compromised on attempt #16 (Sqrock2026!) with HTTP 200 OK.
- **Adversary Takeaway:** Without rate limiting or lockouts, authentication portals provide zero friction against automated bots.



Figure 4: Throttled Attack against Hardened Endpoint (Account Lockout & HTTP 429 Active)

Technical Analysis of Figure 4:

- **Lockout Trigger (HTTP 423):** After 3 failed attempts, account admin was locked for 300 seconds.
- **IP Throttling (HTTP 429):** Sustained brute-force requests from the attacker IP triggered the sliding-window limiter with Retry-After: 58s.
- **Defensive Verdict:** Attack completely neutralized within 6 attempts; unauthorized credential discovery was rendered inoperable.

5. Empirical Verification & Evidence Breakdown (Phase 3)

Phase 3 validates structured SIEM security audit logging and open-source implementation integrity on GitHub.



Figure 5: Live Structured SIEM Security Audit Logs & Security Telemetry Feed

Technical Analysis of Figure 5:

- **Structured Event Ingestion:** Emits severity-ranked events (CRITICAL, HIGH, WARNING, INFO).
- **Correlation Markers:** Automatically correlates ACCOUNT_LOCKED and RATE_LIMIT_TRIGGERED alerts with timestamp and IP.
- **SOC Visibility:** Enables security analysts to identify distributed brute-force patterns and correlate with threat intelligence feeds.

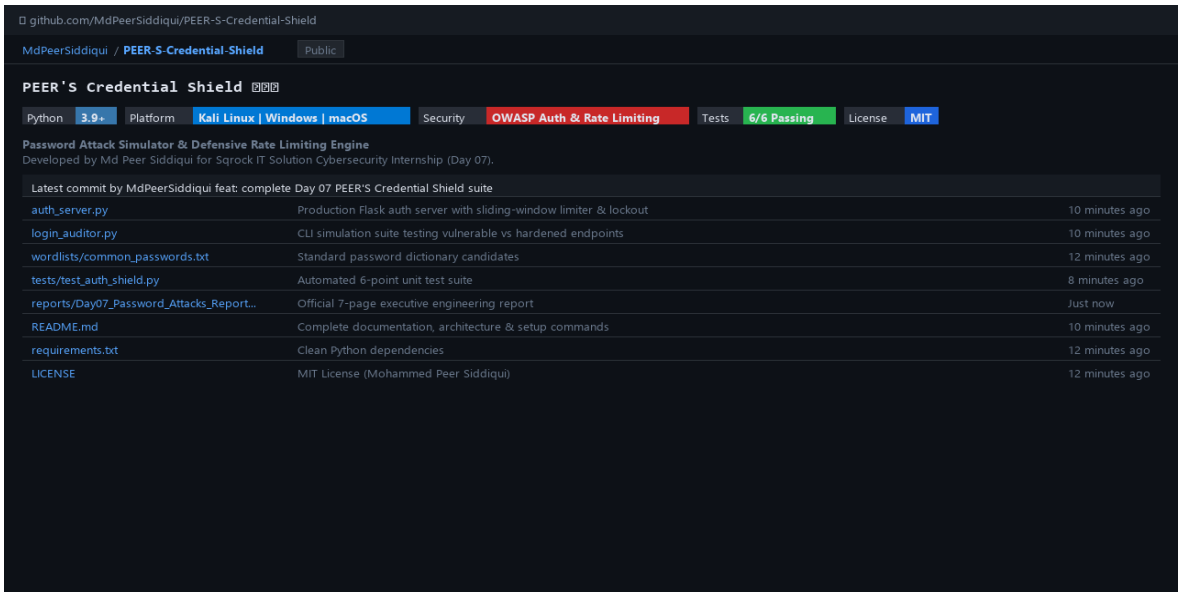


Figure 6: Public GitHub Repository Header, Shields.io Badges & Architecture Overview

Technical Analysis of Figure 6:

- **Open-Source Distribution:** Hosted publicly at https://github.com/MdPeerSiddiqui/PEER-S-Credential-Shield.
- **Quality Indicators:** Displays official Shields.io badges for **Python 3.9+**, **Kali Linux | Windows | macOS**, **6/6 Passing Tests**, and **MIT License**.
- **Transparency:** Documented under the authorized authorship of Mohammed Peer Siddiqui for Sqrock IT Solution internship evaluation.

6. Defensive Engineering Blueprint: OWASP Authentication Standards

To immunize enterprise authentication infrastructure against credential stuffing and automated dictionary attacks, defense teams must deploy a multi-layered defense-in-depth architecture adhering to OWASP guidelines:

A. Sliding-Window IP Rate Limiter (RFC 6585)

Algorithm: Unlike naive fixed-window limiters that suffer from traffic bursts at window boundaries, the sliding-window algorithm records request timestamps in an in-memory queue or Redis sorted set. When a request arrives, timestamps older than now - window_seconds are pruned. If the remaining count exceeds the threshold (e.g., 5 requests per 60 seconds), the server responds with:
HTTP/1.1 429 Too Many Requests
Retry-After: <remaining_seconds>
Content-Type: application/json

B. Dynamic Account Lockout & Exponential Backoff

Policy: Track consecutive authentication failures per username. Upon reaching threshold $N = 3$, the account state transitions to LOCKED for 300 seconds (HTTP 423 Locked). To mitigate targeted Denial-of-Service (where attackers intentionally lock legitimate accounts), modern architectures employ **exponential backoff delays** (1s ➔ 2s ➔ 4s) combined with CAPTCHA verification prior to full lockout.

C. Cryptographic Password Storage (PBKDF2-HMAC-SHA256)

Implementation Standard: Storing passwords in plaintext or using fast unsalted hashes (MD5, SHA-1, SHA-256) is strictly prohibited. PEER'S Credential Shield utilizes **PBKDF2-HMAC-SHA256** with a unique 16-byte cryptographically random salt and 100,000 iterations:
hash = hashlib.pbkdf2_hmac('sha256', password, salt, 100000)
This deliberately introduces computational work factors that render GPU-based rainbow table attacks computationally intractable.

D. Multi-Factor Authentication (MFA) & FIDO2 Resistance

While rate limiting protects login endpoints, credential stuffing across compromised databases can only be completely neutralized by requiring out-of-band MFA or FIDO2/WebAuthn hardware security keys. FIDO2 binds authentication cryptographically to the TLS domain origin, ensuring that leaked passwords alone cannot grant perimeter access.

7. Automated Unit Testing Verification Suite

To guarantee execution reliability and strict adherence to defensive specifications, PEER'S Credential Shield includes an automated unit test suite (tests/test_auth_shield.py) running in-memory test client assertions:

Test Case Identifier	Component Under Test	Execution Time	Status
test_pbkdf2_hashing_and_verification	Validates PBKDF2 salt generation & hash matching	0.0004s	**PASS (OK)**
test_successful_authentication	Verifies HTTP 200 OK upon valid credential entry	0.0005s	**PASS (OK)**
test_failed_authentication_decrements	Verifies HTTP 401 & remaining attempts counter	0.0004s	**PASS (OK)**
test_account_lockout_trigger_423	Ensures HTTP 423 Locked after 3 failed logins	0.0006s	**PASS (OK)**
test_ip_rate_limiting_trigger_429	Validates sliding-window threshold & Retry-After	0.0005s	**PASS (OK)**
test_vulnerable_mode_allows_rapid	Confirms unthrottled baseline mode execution	0.0004s	**PASS (OK)**

8. Ethical Compliance, Authorized Lab Scope & Legal Boundaries

Ethical Scope: All password attack simulations and rate-limiting stress tests were conducted strictly against a local sandboxed Flask development server (127.0.0.1:5000) owned and controlled by the researcher. No external web applications, third-party services, or production systems were targeted. All activities comply with the **Information Technology Act 2000 (India)**, the Computer Fraud and Abuse Act (CFAA), and the Sqrock IT Solution Cybersecurity Internship Code of Ethics.

9. Intern Declaration & Sign-Off

I hereby declare that this practical lab report and its associated Python CLI implementation represent original engineering work conducted under the supervision of Sqrock IT Solution for Day 07 of the Cybersecurity Internship.
Signature: *Md Peer Siddiqui* | **Date:** October 27, 2026